ICM0032 IT valitsemine ja juhtimine — Loeng 3

Talitluspidevuse ja avariitaaste planeerimine (Business Continuity and Disaster Recovery Planning)

Loengukonspekt videoloengu ja slaidide põhjal. Seos ainekavaga: alam-õpiväljundid 3.a–3.e. Loengukimbu test (Risk Management + BC/DR) toimub 5. nädalal.

> **Eksamifookus lühidalt.** Õppejõud rõhutas eraldi: (1) nelja R-i joonis „business as usual → intsident → alternatiivne protsess → taastamine → business as usual" koos RTO-ga — seda peab oskama eksamil reprodutseerida; (2)
>
> BIA, MTD ja prioritiseerimine — „kui need võtmesõnad ja nende tõlgendus on selged, on põhiline olemas"; (3) RTO ja RPO mõisted; (4) BCM ei korruta mõju tõenäosusega; (5) IT-l ei ole talitluspidevuse plaani, vaid avariitaaste plaan. **Ei ole vaja pähe õppida:** standardite numbreid, MTBF/MTTR-i, käideldavuse tabelit, katastroofide liike, NIST-i ja ISO 22317 sisu, tüüpilise BCP protsessi skeemi.

---

1. Miks talitluspidevus? Kindluse mentaliteedist kohanemisvõimeni

Kindluse mentaliteet (*fortress mentality*) eeldab, et kui ümber on piisavalt valle ja kraave, ei saa midagi halba juhtuda. Tänapäeval on see lähenemine:

- **staatiline** — maailm muutub kiiresti ja homsed ohud saavad vallidest üle;
- **aeglane** — iga parendus võtab palju aega;
- **ebatõhus** — suurte kulutustega saadakse vähe turvalisust.

Ressursid on piiratud, seega tuleb end kaitsta **vähe kulutades, kuid tõhusalt** ja kohaneda kiiresti muutuva keskkonnaga.

Talitluspidevuse areng: algul küsiti, mida teha, kui arvutuskeskus ei toimi → seejärel IT-süsteemide taastamine (*disaster recovery*) → kogu ettevõtet hõlmavad plaanid (ERM-i analoogina) → tänapäevane tase: **terviklikud, kontrollitud ja testitud plaanid kõikideks olukordadeks**. Areng on liikunud üksikute külgede kaitsmiselt ettevõtte terviklikule käsitlusele.

2. Riskiahel: enne ja pärast sündmust

Faas	Element	Eesmärk
Enne sündmust	Oht (*hazard*): ennetamine, tuvastamine, seire	Minimeerida sündmuse tõenäosust
Enne sündmust	Kokkupuude (*exposure*): riskikontroll, kaitse, kindlustus	Minimeerida kahju, kui sündmus juhtub

Faas	Element	Eesmärk
Pärast sündmust	Vastupanuvõime (*resiliency*): reageerimisvõime, robustsus, kohanemisvõime	Taluda lööki
Pärast sündmust	Situatsiooniplaanid (*contingency*): taastamine, parandamine, kohandumine	Toime tulla sündmuse põhjustatud kahjuga

Eelmine loeng (riskijuhtimine) käsitles **aega enne sündmust**. Talitluspidevus (BC) käsitleb **aega pärast sündmust**: kuidas olla tõrkekindel ja kuidas taastada toimivus — kui mitte täielikult, siis vähemalt põhifunktsioonid.

3. Talitluspidevuse halduse (BCM) eesmärk

Joonisel on teljed **ärivõimekus** ja **aeg**; halb sündmus viib võimekuse alla. Kolm stsenaariumi:

- **Roheline — toimiv, testitud BCM:** väike ajutine tagasilöök, kiire taastumine ja jätkuv kasv.
- **Punane — BCM puudub (tõenäoline tulemus):** võimekus langeb väga palju, võib-olla nullini; taastumine on ebapiisav. Kui **kriitilise taastamise punktiks** ei ole saavutatud teatud võimekust, on ettevõtte edasine toimimine küsimärgi all.
- **Kollane — BCM puudub, kuid „vedas":** õnnelikke juhuseid on, kuid sellele ei saa lootma jääda.

4. BCM-i põhikomponendid

- **Riskihindamine** (*risk assessment*): mille eest kaitsta (ohud) ja mida kaitsta (varad).
- **Äriliste mõjude analüüs** (*business impact analysis*, BIA): riskihindamise „paariline" teisest vaatenurgast — mida halb sündmus ärile tähendab.
- Nende põhjal tekivad **kaitsenõuded** (*protection requirements*), millest lähtub kaks teed:
  - **riskikäsitlus** (*risk treatment*) — tugevdada kontrolle, et mitte pihta saada („mitte valu tunda");
  - **talitluspidevuse planeerimine** (BCP) — mida teha, kui oleme pihta saanud („kuidas valust üle saada").

5. Talitluspidevuse planeerimine ja selle „taburet"

BCP on pidev protsess, mille käigus tuvastatakse võimalikud riskid ja töötatakse välja leevendusstrateegiad, et minimeerida suure häire mõju.

Taburet ehk BCP kolm jalga ja neid ühendav osa:

Osa	Sisu	Kelle vastutus
ERP — hädaolukorrale reageerimine (*emergency response*)	Vältida inimelude kaotust, minimeerida vigastusi, kaitsta vara	Äri
DRP — avariitaaste (*disaster recovery*)	Taastada IT-infrastruktuur, rakendused ja andmed	IT
BRP — äritegevuse jätkamine (*business resumption*)	Tagada tegevuse taasalustamine; viimane faas, algse olukorra taastamine	Äri
Hädaolukorra kommunikatsioon (*emergency communication*)	Tõhus suhtlus töötajate, võtmetarnijate, klientide jt-ga	Ühine

> **Oluline:** talitluspidevuse see osa, mis puudutab otseselt IT-d, on **avariitaaste**. Hädaolukorrale reageerimist ja äritegevuse jätkamist peab äripool planeerima, harjutama ja läbi viima.

Kontekst Eestis: pangad on elutähtsa teenuse osutajad. Nimekirjas on nimeliselt kolm panka — Swedbank, SEB Eesti ja Luminor —, kelle riskihalduse ja eriti talitluspidevuse nõuded (Finantsinspektsiooni järelevalve all) on teistest oluliselt rangemad.

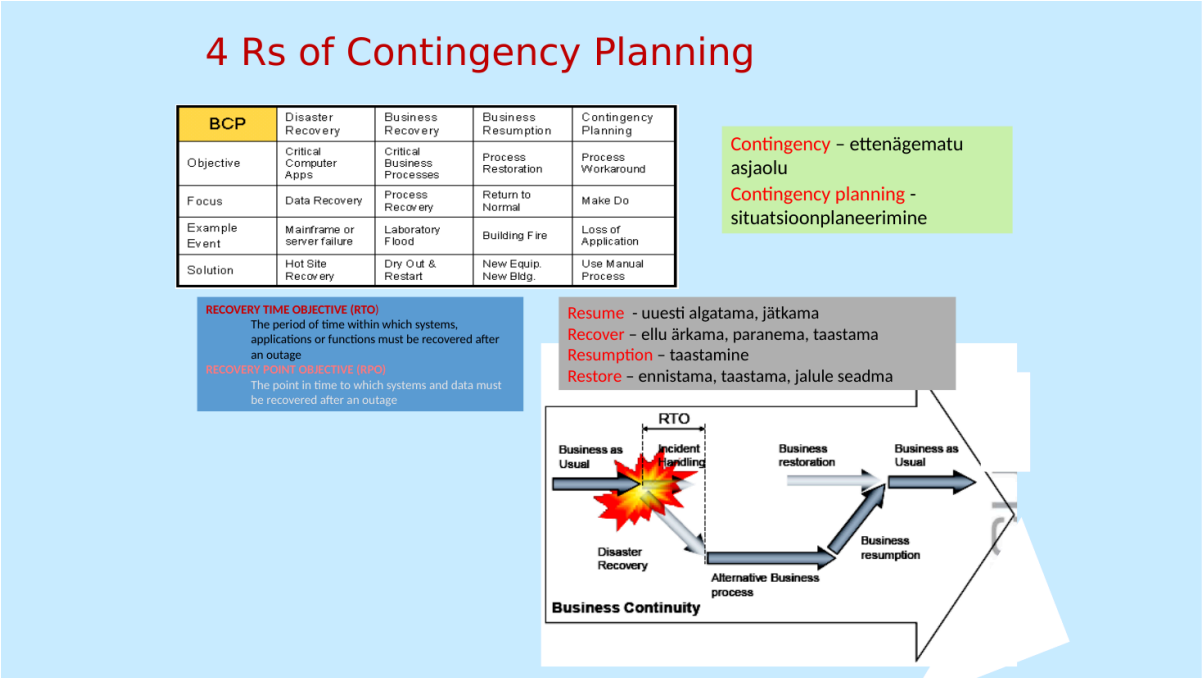
6. Reageerimise ja taastamise faasid

1. **Hädaolukorrale reageerimine** (*emergency response*) — **esikohal on alati inimelud** (*life-safety*, kohe). Laeva näide: reisijate ohutus on kõrgeim prioriteet, kõik muu tuleb hiljem. Samuti tuleb aru saada, mis juhtus.
2. **Kahjude hindamine** (*damage assessment*), nt 24–48 tundi.
3. **Lühiajaline taastamine** (*short-term recovery*), nt 1 päev – 3 nädalat: **möödapääs** (*workaround*) ehk alternatiivne lahendus, nt kolimine sekundaarsesse andmekeskusesse või varutöökohtadele.
4. **Pikaajaline taastamine** (*long-term recovery*), kuudest aastateni: algse olukorra taastamine.

Ajad on vaid näitlikud ja sõltuvad ettevõtte suurusest, riigist ja valdkonnast.

Taastamise loogika kolmes sammus: **(1) peata katastroofi levik → (2) leia möödapääs, et funktsioone kas või osaliselt täita → (3) taasta algsed funktsioonid.**

7. Situatsiooniplaneerimise neli R-i, RTO ja RPO ⭐ EKSAMIJOONIS



Seda joonist peab oskama eksamil reprodutseerida.

```
Business as usual ──► [INTSIDENT] ──► intsidendihaldus / avariitaaste
                          │              (kestus = RTO)
                          ▼
                Alternatiivne äriprotsess (osaline võimekus)
                          │
                          ▼
             Business resumption (äritegevuse jätkamine)
                          │
                          ▼
    Business restoration (algse protsessi taastamine)
                          ▼
                Business as usual
```

Järjestus sõnades:

1. **Business as usual** — äri toimib tavapäraselt.
2. **Intsident** — äriline võimekus langeb järsult.
3. **Intsidendihaldus ehk hädaolukorrale reageerimine** ja IT poolel **avariitaaste**.
4. **RTO jooksul** tuleb käivitada **alternatiivne äriprotsess** — võib-olla teises asukohas või hoopis teistmoodi (nt pliiatsi ja paberiga). Selle võimekus on väiksem: osaline, aeglasem, halvemate parameetritega.
5. Kui alternatiivne protsess töötab, **vabanevad ressursid** ja algab algse protsessi **taastamine** (*restoration*) ja **äritegevuse jätkamine** (*resumption*).
6. Tagasi **business as usual** seisu.

Terminid ja tõlked:

Termin	Eesti keeles
Contingency	ettenägematu asjaolu
Contingency planning	situatsiooniplaneerimine
Resume	uuesti algatama, jätkama
Recover	ellu ärkama, paranema, taastama
Resumption	taastamine, jätkamine
Restore	ennistama, taastama, jalule seadma

Kaks strateegilist parameetrit:

- **RTO — taasteaja eesmärk** (*recovery time objective*): ajavahemik, mille jooksul süsteemid, rakendused või funktsioonid tuleb pärast katkestust taastada. „Taastada" tähendab siin, et need võivad töötada **osalise funktsionaalsusega** — RTO lõpuks peab alternatiivne protsess käima. RTO on **strateegiline parameeter**, mis tuleb määrata iga äriprotsessi planeerimisel: kauem ei tohi protsess maas olla. Näide: kui pangakaardid ei tööta panga süül üle 30 minuti, tuleb anda pressiteade.
- **RPO — taastepunkti eesmärk** (*recovery point objective*): ajahetk, milleni süsteemid ja andmed tuleb pärast katkestust taastada. Praktikas: **kui kaua aega tagasi tehti viimane varukoopia** ehk kui palju andmeid (nt tehinguid) tohib kaduma minna. Finantsasutustes on RPO sageli **null**.

Y2K näide (Eesti Ühispank, 1999): kõik seadmed inventeeriti ja testiti; kontorites prinditi õhtul välja eraisikute kontojäägid, et tellerid saaksid vajaduse korral „küünlavalgel" raha välja anda — see oli alternatiivne protsess. Erisus: Y2K puhul **oli täpselt teada, millal oht saabub**. Tavaliselt ei tea me, millal halb sündmus juhtub.

4 R-i tabel (ei ole eksami osa, kuid aitab mõista):

	Avariitaaste	**Äriline taastamine**	**Äritegevuse jätkamine**	**Situatsiooniplaneerimine**
Eesmärk	Kriitilised arvutirakendused	Kriitilised äriprotsessid	Protsessi taastamine	Protsessi möödapääs
Fookus	Andmete taastamine	Protsessi taastamine	Tagasi normaalseisu	Hakkama saamine
Näide	Suurarvuti või serveri rike	Üleujutus laboris	Tulekahju hoones	Rakenduse kadumine
Lahendus	Kuuma varukeskuse (*hot site*) kasutamine	Kuivatamine ja taaskäivitus	Uued seadmed, uus hoone	Käsitsi protsess

8. Talitluspidevuse dokumendid

Fookus	IT	Äri
Sündmusest taastumine	Avariitaaste plaan (*disaster recovery plan*) — taastamine varukohas; IT situatsiooniplaan (*IT contingency plan*) — suurema rakenduse või süsteemi taastamine; küberintsidendile reageerimise plaan (*cyber incident response plan*)	Äritegevuse taastamise plaan (*business recovery plan*); hoones viibijate hädaolukorra plaan (*occupant emergency plan*) — elude ja vara kaitse füüsilise ohu korral; kriisikommunikatsiooni plaan (*crisis communication plan*)
Talitluspidevus	— IT-l ei ole talitluspidevuse plaani	Talitluspidevuse plaan (*business continuity plan*); tegevuse jätkamise plaan (*continuity of operations plan*) pikemate katkestuste jaoks

9. ERM vs BCM — olulisim erinevus ⭐

Mõlemad tegelevad halbade sündmustega ja jagavad enamikku ajendeid (vastavus regulatsioonidele, maine kaitse, sidusrühmade ootused, valitsemise ootused, üllatuste vältimine jne). **BCM ei käsitle:**

- äri ja IT joondamist (*business-IT alignment*);
- programmide ja protsesside tõhusust — **tõhusus on sekundaarne, peamine on taastada funktsionaalsus**;
- kapitali optimeerimist;
- **riski tõenäosuse haldamist.**

> **Võtmemõte:** riskijuhtimises on risk = mõju × tõenäosus, nii et väga väikese tõenäosusega sündmus on väike risk isegi suure mõju korral. **Talitluspidevuses tõenäosusega ei korrutata: kui võimalik kahju on suur, peab olema talitluspidevuse plaan olenemata tõenäosusest.** Sama loogikat kasutavad sageli audiitorid leidude kriitilisust hinnates.

10. Reageerimise tasemed

- **Strateegiline:** intsidendihalduse plaan, reageerimismeeskonnas tippjuhtkond.
- **Taktikaline:** plaanid suuremate üksuste, toodete, teenuste või asukohtade kaupa; meeskonnas vastavad juhid.
- **Operatiivne:** tavaliselt taktikaliste plaanide osa, välja arvatud tugifunktsioonid (IT, finants, kinnisvara ja rajatised, personal), millel on oma taastemeeskonnad.

Intsidendi tase määrab, milline kriisimeeskond sellega tegeleb.

11. Standardid ja PDCA

Standard on kristalliseerunud kogemus. Lapse sünnipäeva näide: pere praktika → linna tava → riigi ja maailma standard. Standardeid kehtestavad standardiorganid (ISO, NIST). Iga ettevõte ei pea ise jalgratast leiutama.

Otse talitluspidevusele suunatud (numbreid ei pea teadma): **ISO 22301** (nõuded), **ISO 22313** (juhised), **ISO 22317** (BIA, tehniline spetsifikatsioon), ISO 27031 (IKT valmisolek talitluspidevuseks). NIST **SP 800-34** — lakooniline ja selge, õppejõu hinnangul sageli arusaadavam kui ISO.

PDCA tsükkel (Deming, 1950. aastate Jaapan) ISO 22301 järgi:

Faas	Sisu
Plan (*Establish*)	Kehtestada BC poliitika, eesmärgid, sihid, kontrollid, protsessid ja protseduurid
Do (*Implement and operate*)	Rakendada ja käitada poliitikat, kontrolle, protsesse ja protseduure
Check (*Monitor and review*)	Jälgida ja hinnata tulemuslikkust võrreldes poliitika ja eesmärkidega
Act (*Maintain and improve*)	Parendada vastavalt vajadusele

Miks harjutamine on kriitiline: tarkvaraarenduses on aega kaaluda alternatiive („tark ei torma"), kriisis aga **mõtlemiseks aega ei ole**. Mõtlemine tuleb teha ette ning kinnistada treeningute ja õppustega: *testida, testida, testida; harjutada, harjutada, harjutada.*

12. Talitluspidevuse planeerimise viis faasi

1. **Juhtkond algatab** projekti — kontekst, ressursid ja ulatus.
2. **Äriliste mõjude analüüs (BIA)** — kogu protsessi tuum.
3. **Taastestrateegiad** — kuidas taastada äri, rajatised ja varustus, kasutajad, tehnika ja andmed.
4. **Plaani koostamine** (*design & develop*) — kriitiliste süsteemide, seejärel mittekriitiliste süsteemide, ärifunktsioonide ja lõpuks kogu ettevõtte taastestrateegiad.
5. **Testimine, koolitus ja hooldus** — plaani toimivuse kontroll (vähemalt kord aastas), ajakohastamine äri ja tehnoloogia muutudes, teadlikkus ja koolitus.

SEB Eesti praktika: kaks töötavat andmekeskust (A ja B); kaks korda aastas (kevadel ja sügisel) kolitakse kõik protsessid ühte keskusesse ja töötatakse väiksema võimekusega edasi. Kord aastas toimub varutöökohtadele liikumise õppus (nt pommiähvarduse stsenaarium Tornimäe majas) ja ette teatamata evakuatsiooniõppus. Suured Euroopa pangad viivad inimesi mitu korda aastas bussidega sadade kilomeetrite kaugusel asuvasse varukeskusesse.

13. Äriliste mõjude analüüs (BIA) ⭐

> „Talitluspidevuse plaan, mis ei põhine BIA tulemustel, on parimal juhul oletus, puudulik ega pruugi tegeliku taastamise ajal toimida." Õppejõud lisas kogu BIA-sektsiooni selleks, et **BIA-d oleks võimatu unustada**.

BIA eesmärgid:

1. **prioritiseerida kriitilised funktsioonid**;
2. määrata kriitiliste funktsioonide nõuded;
3. **hinnata maksimaalne talutav seisakuaeg (MTD)**.

BIA sammud (detaile ei pea teadma): infokogumise meetodite valik → intervjueeritavate valik (äriprotsesside omanikud) → küsimustiku kohandamine → info analüüs → **ajakriitiliste ärifunktsioonide määramine** → **MTD määramine** → **kriitiliste funktsioonide prioritiseerimine MTD alusel** → raport ja taastesoovitused.

MTD — maksimaalne talutav seisakuaeg (*maximum tolerable downtime*): kui kaua võib iga oluline ärifunktsioon olla maas, ilma et äritegevus oluliselt kahjustuks. Määratakse **iga ärifunktsiooni kohta eraldi**. Kuna funktsioone on palju, on MTD **prioritiseerimise alus**: mida lühem MTD, seda varem tuleb tegutseda.

MTD näited (numbreid ei pea teadma):

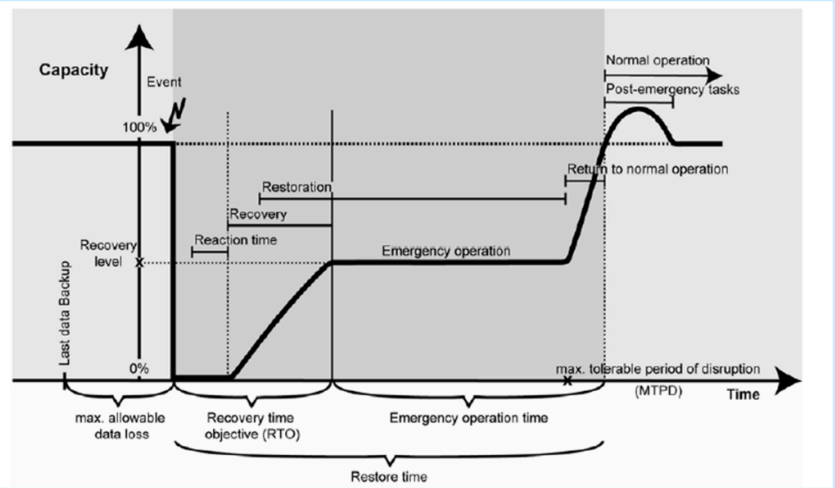
Kategooria	MTD
Mitteoluline	30 päeva
Tavaline	7 päeva
Oluline	72 tundi
Kiireloomuline	24 tundi
Kriitiline	minutid kuni tunnid

Loogiline ahel: BIA → MTD → prioritiseerimine → strateegia, kuidas hädaolukorras toimida.

Sündmuste astmed: teenuse katkestus (mitte-katastroof), katastroof, suurõnnetus. Seadmete puhul **MTBF** (keskmine tõrgetevaheline aeg) ja **MTTR** (keskmine parandusaeg) — neid ei pea eksamiks teadma.

14. Talitluspidevuse mõõdikud ajateljel

BC Metrics



25

Joonist ei pea reprodutseerima, kuid **mõisteid peab teadma**:

1. Sündmus → võimekus langeb 100%-lt 0%-le.
2. **Reaktsiooniaeg** — midagi ei toimi, valmistutakse taastamiseks.
3. **Taastamine** (*recovery*) → käivitub **alternatiivne protsess** vähendatud võimekusega (*recovery level*).
4. **Hädaolukorra toimingud** (*emergency operation*), sageli sekundaarses andmekeskuses.
5. Paralleelselt, võib-olla juba enne alternatiivse protsessi käivitumist, algab **algse protsessi taastamine** (*restoration*).
6. **Tavatööle naasmine**; ajutiselt võib võimekus isegi ületada algset, sest tuleb teha lisatöid (*post-emergency tasks*).

Parameeter	**Tähendus**
RTO	Aeg nullvõimekusest alternatiivse protsessi käivitumiseni (protsess on täielikult seisatud)
Hädaolukorra toimingute aeg	Kui kaua alternatiivne protsess töötab
Taasteaeg (*restore time*)	Aeg nullist kuni algse protsessi ennistamiseni
Maksimaalne lubatav andmekadu = RPO	Viimasest varukoopiast kuni sündmuseni
MTPD	Maksimaalne talutav häireaeg (*maximum tolerable period of disruption*)

Kaks RTO väärtust: RTO min (SLA) on aeg, mille jooksul käivitatakse alternatiivne protsess SLA-kohase minimaalse teenustasemega. **RTO (normal operation)** on aeg, mille jooksul saavutatakse taas normaalne võimekus. Oluline on vaadata, kuidas RTO konkreetses kontekstis on defineeritud.

Käideldavus (tabelit ei pea teadma):

Käideldavus	Seisak aastas	Seisak nädalas
98%	7,3 päeva	3 h 22 min
99%	3,65 päeva	1 h 41 min
99,9%	8 h 45 min	10 min 5 s
99,99%	52,5 min	1 min
99,999% („viis üheksat")	5,25 min	6 s
99,9999%	31,5 s	0,6 s

Ülikõrget käideldavust nõutakse suurtelt börsiettevõtetelt, suurpankadelt (nt Deutsche Bank, Citigroup) ja energeetikaettevõtetelt.

15. ISO 22317 ja BIA mõjukategooriad

ISO 22317 on BIA-le pühendatud standard (sisu ei pea teadma). Definitsioon: BIA analüüsib häiriva intsidendi tagajärgi organisatsioonile ning selle väljund on **talitluspidevuse nõuete põhjendus**. Eraldi standardi olemasolu rõhutab BIA tähtsust.

Mõjukategooriad:

Kategooria	Näide
Finantsiline	Trahvid, sanktsioonid, saamata jäänud kasum, turuosa vähenemine
Maine	Negatiivne arvamus, brändikahju (kaardimakse ei toimi → klient vahetab panka)
Õiguslik ja regulatiivne	Kohtuvaidlused, tegevusloa kaotus (Finantsinspektsioon)
Lepinguline	Lepinguliste kohustuste rikkumine
Ärieesmärgid	Eesmärkide täitmata jäämine, võimaluste kasutamata jätmine — seotud otse strateegiaga

Mainekahju ja muud kahjud väljenduvad lõpuks enamasti ka **rahaliselt**.

Juhtum „Mamma Mia!": Eesti Energia lõikas remonditööde käigus läbi kaks sõltumatut kaablit. UPS rakendus, kuid tühjenedes andis viimase impulsi, mida generaator tõlgendas nii, et UPS veel töötab,

ja generaator ei käivitunud. Täisautomaatika tõttu ei saanud inimesed sekkuda. Õppetund: paigaldati **käsilüliti**, mis võimaldab generaatori käivitada automaatikast sõltumata.

16. Mitmetasandiline prioritiseerimine ja taastestrateegiad

BIA põhineb **mitmetasandilisel prioritiseerimisel** (ISO 22317):

1. **Tooted ja teenused** — järjestatakse MTD alusel; juhtkond peab prioriteedid heaks kiitma.
2. **Protsessid** — millised protsessid millist teenust toetavad; protsessi prioriteet tuleneb tema väljundiks olevate toodete ja teenuste prioriteedist; sõltuvuste analüüs.
3. **Tegevused** (*activities*) — igapäevased ressursivajadused: inimesed ja oskused, rajatised ja seadmed, dokumendid, rahastus, IKT (rakendused, andmed, telefonid, võrgud), tarned ja partnerid.

Pärast BIA-d valitakse talitluspidevuse strateegiad: alternatiivsed töökohad, alternatiivsed tarneahelad, IT taastamise võimalused, alternatiivsed inimesed ja seadmed, möödapääsud ja alternatiivsed protseduurid.

Taastestrateegiate liigid: äriline taastamine (MTD), rajatiste ja tarnete taastamine, kasutajate taastamine (personal), tehniline taastamine (kuum, soe või külm varukoht), andmete taastamine (varukoopiad).

> **IT-inimesed eksisteerivad selleks, et äriinimesed oleksid õnnelikud.** Tegelik eesmärk on äriprotsessi ja äriteenuse taastamine, seega on **äriline taastamine koos MTD-ga kõige olulisemad näitajad**.

Mõju protsesside kaupa: protsessid jaotatakse rühmadesse — kriitiline, kõrge, keskmine ja madal mõju. Kriitilise mõjuga protsessid tuleb käsitleda kohe.

Platvormi ja andmete strateegiate kombineerimine BIA tulemuste põhjal:

Platvorm ↓ / Andmed →	**Sünkroonne peegeldamine (RPO null)**	**Asünkroonne peegeldamine (sekundid–minutid)**	**Kettakoopia (tunnid)**	**Lindilt taastamine (12 h – päevad)**
Kuum ooteseisund (RTO minutid)	✓	✓	✓	—
Soe ooteseisund (tunnid)	✓	✓	✓	✓
Külm ooteseisund (päevad)	✓	✓	✓	✓
Avariitaaste ooteseisund puudub (nädalad)	—	—	—	✓

Pangatehingute puhul on RPO praktiliselt null; andmekadu võib olla lubatud vaid abiprotsesside puhul.

17. Talitluspidevuse halduse elutsükkel ja tüüpiline BCP protsess

Elutsükkel: ennetus (*pre-empt & prevent*, vähendamine) → **reageerimine** (minutid kuni tunnid) → **taastamine ja jätkamine** (tunnid kuni päevad) → **ennistamine ja tagasipöördumine** (nädalad kuni kuud).

Tüüpiline BCP protsess (SEB praktikale lähedane; skeemi ei pea reprodutseerima):

1. Organisatsiooni ressursid ja projekti algatamine
2. BCP poliitika ja ulatuse määramine
3. Riskide ja nende maandamise tuvastamine (olemasolevad kaitsed)
4. **Äriliste mõjude analüüs** — projekti tuum
5. Taastestrateegiate väljatöötamine
6. Plaani koostamine ja testimine
7. Juhtkonna teadlikkus ja koolitus; BCP ülevaatus, testimine ja verifitseerimine; BCP hooldus ja muudatuste haldus

18. Intsidentide haldus

Intsidentide haldus on talitluspidevuse **praktiline täiendus**: BCM teeb plaanid ette, intsidendi korral neid rakendatakse. *Management* on siin õppejõu soovitusel parem tõlkida **halduseks**, sest intsidendi tekkimist me ei kontrolli.

> „Ettevõtteid on kahte sorti: need, keda on häkitud, ja need, keda on häkitud, kuid kes seda veel ei tea." Absoluutset kaitset ei ole.

Definitsioon: intsident on **vaenulik sündmus, mis ohustab arvutisüsteemide ja -võrkude turvalisust**. Sündmus (*event*) on mis tahes jälgitav toiming süsteemis või võrgus. Vaenulikud sündmused on näiteks süsteemi krahh, võrgu üleujutamine pakettidega, teise kasutaja konto või õiguste volitamata kasutamine, veebilehe rikkumine või andmeid hävitava pahavara käivitamine. Turvalisust mõistetakse **CIA-triaadi** kaudu: konfidentsiaalsus, terviklikkus ja käideldavus. Ka tõrked on vaenulikud sündmused.

Seotud standardid (ei pea teadma): ISO 27035 (intsidentide haldus), ISO 27001, NIST SP 800-61.

Intsidentide halduse tegevused:

1. **Teadete vastuvõtmine** — kõigepealt tuleb üldse aru saada, et midagi juhtus → vaja on **seiresüsteeme**. Näide: Risto Vaarandi *Simple Event Correlator* (SEC), mida kasutatakse üle maailma. SEB Eesti seireruumis on vähem kui 20 kuvarit, Rootsi keskuses üle 100.
2. **Intsidendi või katastroofi väljakuulutamine** — intsidendi võib välja kuulutada seiretöötaja; **katastroofi** väljakuulutab kriisikomitee juht (pangas sageli president).
3. **Kommunikatsioon** sise- ja välissuunal (nt pressiteade, kui kaardid ei tööta üle 30 minuti).
4. **Tegevuste dokumenteerimine** — kes avastas, mida tehti, kuidas toimiti. Raporti põhjal saab parendada nii protsessi ennast kui ka seda tüüpi intsidentide käsitlemise protsessi.

Ajajoon: BCM (hädaolukorra planeerimine) → **intsident** → **intsidendile reageerimine** (*incident response*) → **intsidendihaldus** (taastamine).

Kolmetasandiline struktuur:

Tase	Meeskond	Ülesanne
Kuld / strateegiline	Tippjuhtkonna meeskond	Sidusrühmade haldus, strateegilised otsused, meediaintervjuud
Hõbe / taktikaline	Intsidendihalduse meeskond (kogu organisatsioon)	Taktikalised otsused, kommunikatsioon, eskaleerimine
Pronks / operatiivne	Äriüksuse juhtkond; IT taastemeeskonnad	Taastamine äri taasteplaanide ja IT talitluspidevuse plaanide järgi

ISO 22301 ajajoon: reageerimine (minutid kuni tunnid: inimeste turvalisus, kahjude piiramine ja hindamine) → **taastamine** (minutid kuni päevad: kriitiliste tegevuste taastamine) → **jätkamine** (nädalad kuni kuud: parandused, püsivasse asukohta naasmine, kulude katmine kindlustusest). Üldeesmärk on jõuda võimalikult kiiresti tagasi normaalolukorda.

19. Intsidentide prioritiseerimine

Lihtne 2×2 maatriks (kasutab ka SEB): **kasutajate arv × süsteemide arv**.

	Üks süsteem	Palju süsteeme
Palju kasutajaid	2. Kõrge	1. Äärmiselt kõrge
Üks kasutaja	4. Madal	3. Tavaline

Kasutajad on primaarsed: kui mõjutatud on palju kasutajaid, on prioriteet kõrgem. Alternatiivina kasutatakse SLA-de, OLA-de, kriitiliste rakenduste erikokkulepete või kliendisoovide põhjal kokku lepitud prioriteedikoode.

Prioriteet	Sisu ja tegevus
1 — äärmiselt kõrge	Kriitilised kesksüsteemid, palju kasutajaid; vastutab intsidendihaldur; kohene tegutsemine, CIO ja süsteemiomanike teavitamine
2 — kõrge	Nt kontori või kõnekeskuse katkestus; kiire tegutsemine tööajal, info iga tunni järel
3 — tavaline	Lõppkasutajate pöördumised teenuslauale, SLA järgi
4 — madal	Tuleb parandada, kuid mõju on peamiselt kvaliteedile

Teenuse sihttasemed (näide):

Prioriteet	Reageerimisaeg	Lahendusaeg	Toetusaeg
Kriitiline	20 min	2 h	24/7
Kõrge	30 min	4 h	24/7
Keskmine	2 h	8 h	E–R 8–17
Madal	8 h	5 tööpäeva	E–R 8–17

Eesmärk on, et 70% intsidentidest vastaks sihttasemele.

- **Reageerimisaeg** (*response time*): staatusest „Uus" kuni staatuseni „Töös". Reageerimine ei tähenda ainult „kohale tulla ja vaadata" (santehniku näide), vaid **reaalseid ettevalmistusi alternatiivse protsessi alustamiseks**.
- **Lahendusaeg** (*resolution time*): staatusest „Uus" kuni staatuseni „Lahendatud"; ootel olek ei lähe arvesse. Sõltub **SLA-st**.
- Tarnijalepingutes on tasemed nagu *Gold* või *Platinum* (tugi 24/7 ja kiire reageerimine); lahjemate lepingute korral on reageerimine aeglasem.

20. Katastroof, BCP ja DRP

Katastroof (*disaster*) on väikese tõenäosuse, kuid **katastroofilise mõjuga** intsident. Konkreetne stsenaarium (tulekahju, üleujutus, küberrünnak, streik jne) ei ole nii oluline kui **taastamisprotsess ja taasteaeg**: katastroofid rühmitatakse tüüpidesse ning BCP jagatakse mooduliteks, mida saab vastavalt vajadusele aktiveerida.

BC vs DR: talitluspidevus (ISO 22301) on **laiem ring**, mille sees on avariitaaste (ISO 27031).

	BCP	DRP
Sisu	Tegevused, mis tagavad kriitiliste äriprotsesside jätkumise	Kahjustatud rajatiste ja süsteemide hindamine, päästmine, parandamine ja taastamine
Vahendid	Alternatiivne personal, seadmed ja rajatised	Tehnilised taastelahendused
Ulatus	Sageli ka mitte-IT aspektid	Keskendub peamiselt IT-süsteemidele

> **IT tegeleb reaalselt avariitaastega; talitluspidevus on äri eesmärk, mida IT toetab.** Nii nagu äri on IT suhtes ülemuslik, on BCP DRP suhtes ülemuslik.

BC–DR püramiid: poliitikakiht (talitluspidevus, poliitikad ja strateegiad) → juhtimiskiht (riskijuhtimine, talitluspidevuse plaanid, valideerimine ja testimine) → infrastruktuurikiht ehk avariitaaste plaan (IT taastamisprotsessid, alternatiivne asukoht, varukoopiad ja väline replikatsioon, serverid, salvestus ja võrk).

21. Kui intsident juhtub

Kutsu turvajuht → turvajuht kuulutab välja hädaolukorra ja järgib eelnevalt kehtestatud protokolli → **hädaolukorra meeskond: esimene mure on inimelud** → **kõnepuu** teavitab asjaosalisi → IT järgib avariitaaste plaani → avalikkussuhtlus suhtleb meediaga (teised on vait) → juhtkond ja jurist tegutsevad.

Kõnepuu (*phone tree*) on IT avariitaaste plaani üks olulisemaid dokumente: kui õigeid inimesi ei saa õigel ajal kätte, ei aita ka parimad oskused.

Avariitaaste tehnoloogiad RPO ja RTO teljel: lindivarundus → asünkroonne replikatsioon → sünkroonne replikatsioon → klasterdamine → kaugreplikatsioon → online-taastamine → lindilt taastamine.

Avariitaaste strateegiate klassid (näide):

Klass	RTO / RPO	Lahendus
1	~0 / ~0	Kaks asukohta ~20 km raadiuses, kuum ooteseisund, peegeldatud andmed
2	8–24 h / 4 h	Varjuandmed (*shadowed data*), oma või sisseostetud
3	72 h / 24 h	Standardne taastamine lindilt; sisseostetud kuum või mobiilne varukoht
4	4–5 päeva / 24 h	Kiirtarne programm; standardne taastamine lindilt

Plaani olulised küsimused:

- **evakuatsiooniplaan — inimelud on alati esikohal** (Tornimäe maja iga-aastane ette teatamata evakuatsioon ilma liftideta);
- **hädaolukorra väljakuulutamine** — kes, kuidas ja mille põhjal (autoriteetne isik);
- **vastutus** — kes täidab avariitaaste funktsioone;
- protseduurid avariitaasteks ja alternatiivses režiimis toimimiseks;
- ressursside jaotus taastamise ja jätkuva töö ajal;
- **plaani koopiad peavad olema ka väljaspool kontorit**.

Vastutusalad: üldised ärifunktsioonid (esmareageerijad, kahjude hindamine, hädaolukorra juhtimine, õigusküsimused, transport ja ümberpaigutamine, varustus, koolitus) ning IT-spetsiifilised

funktsioonid (tarkvara, rakendused, hädaolukorra operatsioonid, võrgu taastamine, riistvara, andmebaasid, infoturve).

22. Lõppmõtted

- **Noa laev** oli esimene taasteplaan: Noa teadis, millal katastroof tuleb, sest tal „olid head sidemed kõrgemale poole". Meie tavaliselt ei tea.
- **Plaan kui dokument ei ole piisav**: kui seda ei ole kommunikeeritud ega harjutatud, on sellest vähe kasu („Jenkins, kas IT avariitaaste plaan on paigas?" — „Jah, söör!").
- **Põhitegevused peavad mahtuma ühele A4-lehele**, sest kriisis ei ole aega pikki dokumente lugeda.
- Tuleb leida **tasakaal tõhususe ja riski ning tõhususe ja nõuetele vastavuse vahel**.

Kordamisküsimused

1. Millise joonise kohta ütles õppejõud, et seda peab oskama eksamil reprodutseerida?

- A) Käideldavuse „üheksate" tabel
- B) Neli R-i: business as usual → intsident → alternatiivne äriprotsess (RTO) → taastamine/jätkamine → business as usual
- C) ISO 22317 sisukord
- D) Tüüpilise BCP protsessi seitsmesammuline skeem

Õige vastus: B

2. Mida tähendab RTO (recovery time objective)?

- A) Aega, mille jooksul tuleb pärast katkestust taastada süsteemid, rakendused või funktsioonid, vähemalt osalise funktsionaalsusega
- B) Viimase varukoopia tegemise aega
- C) Keskmist aega kahe tõrke vahel
- D) Aega, mil süsteem on aastas maas

Õige vastus: A

3. Mida näitab RPO (recovery point objective) praktikas?

- A) Kui kiiresti peab alternatiivne protsess käivituma
- B) Kui kaua aega tagasi tehti viimane varukoopia ehk kui palju andmeid tohib kaduma minna
- C) Kui palju töötajaid tohib evakuatsioonil puududa
- D) Maksimaalset seisakuaega nädalas

Õige vastus: B

4. Milline on RPO tüüpiliselt pangatehingute töötlemisel?

- A) 24 tundi

- B) 4 tundi
- C) Praktiliselt null
- D) Üks nädal

Õige vastus: C

5. Milline on BCM-i ja ERM-i olulisim erinevus riskide käsitlemisel?

- A) BCM arvestab ainult väikese tõenäosusega sündmusi
- B) BCM-is ei korrutata mõju tõenäosusega: kui võimalik kahju on suur, on plaan vajalik olenemata tõenäosusest
- C) BCM keskendub kapitali optimeerimisele
- D) BCM hindab ainult IT ja äri joondatust

Õige vastus: B

6. Milline talitluspidevuse planeerimise „tabureti" jalg on peamiselt IT vastutusel?

- A) Hädaolukorrale reageerimine (ERP)
- B) Äritegevuse jätkamine (BRP)
- C) Avariitaaste (DRP)
- D) Kriisikommunikatsioon

Õige vastus: C

7. Mis on hädaolukorrale reageerimisel alati esimene prioriteet?

- A) Serverite ja andmete päästmine
- B) Pressiteate andmine
- C) Inimelud ja ohutus
- D) Kindlustusseltsi teavitamine

Õige vastus: C

8. Mis on äriliste mõjude analüüsi (BIA) põhieesmärgid?

- A) Prioritiseerida kriitilised funktsioonid, määrata nende nõuded ja hinnata maksimaalne talutav seisakuaeg (MTD)
- B) Arvutada iga riski mõju ja tõenäosuse korrutis
- C) Valida tarnija ja sõlmida SLA
- D) Koostada kõnepuu

Õige vastus: A

9. Milleks kasutatakse BIA-s maksimaalset talutavat seisakuaega (MTD)?

- A) Varukoopiate sageduse määramiseks
- B) Ärifunktsioonide prioritiseerimiseks: mida lühem MTD, seda kiiremini tuleb tegutseda
- C) Töötajate koolituste sageduse määramiseks

- D) Seadmete MTBF-i arvutamiseks

Õige vastus: B

10. Milline väide IT dokumentide kohta on õppejõu rõhutuse järgi õige?

- A) IT-l on oma talitluspidevuse plaan, mis on äri omast ülemuslik
- B) IT-l ei ole talitluspidevuse plaani, vaid peamiselt avariitaaste plaan
- C) IT-l ei ole ühtegi hädaolukorra plaani
- D) IT ja äri plaanid on identsed

Õige vastus: B

11. Kuidas suhestuvad talitluspidevus (BC) ja avariitaaste (DR)?

- A) Need on sünonüümid
- B) DR on laiem ja hõlmab BC-d
- C) BC on laiem ja hõlmab DR-i; BC käsitleb kriitilisi äriprotsesse (ka mitte-IT), DR IT-süsteemide taastamist
- D) Need ei ole omavahel seotud

Õige vastus: C

12. Milles seisnes aasta 2000 (Y2K) ohu erisus võrreldes tavapäraste hädaolukordadega?

- A) See puudutas ainult suurarvuteid
- B) Oli täpselt teada, millal oht võib saabuda
- C) See ei nõudnud alternatiivset protsessi
- D) See oli puhtalt äriline, mitte tehniline risk

Õige vastus: B

13. Miks peetakse talitluspidevuse plaanide harjutamist ja testimist kriitiliseks?

- A) Sest standard nõuab ilusat dokumenti
- B) Sest kriisis ei ole aega mõelda: otsused peavad olema ette läbi mõeldud ja õppustega kinnistatud
- C) Sest testimine asendab BIA
- D) Sest harjutamine vähendab sündmuse tõenäosust

Õige vastus: B

14. Kuidas prioritiseeritakse intsidente lihtsa 2×2 maatriksi järgi (kasutajad × süsteemid)?

- A) Palju kasutajaid ja palju süsteeme = äärmiselt kõrge prioriteet; üks kasutaja ja üks süsteem = madal prioriteet
- B) Kõik intsidendid on võrdse prioriteediga
- C) Prioriteedi määrab ainult süsteemi vanus
- D) Üks süsteem ja palju kasutajaid = madal prioriteet

Õige vastus: A

15. Kes kuulutab panga näitel välja katastroofi (disaster)?

- A) Iga seiretöötaja
- B) Teenuslaua operaator
- C) Kriisikomitee juht, sageli panga president
- D) Tarnija tugiteenus

Õige vastus: C

16. Millises järjekorras toimuvad intsidendi ajajoone faasid ISO 22301 järgi?

- A) Taastamine → reageerimine → jätkamine
- B) Reageerimine → taastamine → jätkamine
- C) Jätkamine → reageerimine → taastamine
- D) Reageerimine → jätkamine → taastamine

Õige vastus: B

17. Milline PDCA faas vastab ISO 22301-s „Monitor and review" tegevusele?

- A) Plan
- B) Do
- C) Check
- D) Act

Õige vastus: C

18. Mida tähendab reageerimisaeg (response time) intsidentide halduses õppejõu selgituse järgi?

- A) Aega, mille jooksul keegi tuleb kohale ja vaatab, mis juhtus
- B) Aega, mille jooksul tehakse vähemalt korralikud ettevalmistused alternatiivse protsessi alustamiseks (staatusest „Uus" staatusesse „Töös")
- C) Aega intsidendi täieliku lahendamiseni
- D) Aega viimasest varukoopiast

Õige vastus: B

19. Mida õpetab „Mamma Mia!" juhtum?

- A) Täisautomaatika on alati usaldusväärsem kui inimene
- B) Kriitilistel süsteemidel peab olema võimalus käsitsi sekkuda (nt käsilüliti generaatori käivitamiseks)
- C) UPS muudab generaatori ebavajalikuks
- D) Elektrikatkestus ei ole talitluspidevuse teema

Õige vastus: B

20. Miks peaksid plaani põhitegevused mahtuma ühele A4-lehele?

- A) Et säästa paberit

- B) Sest standard keelab pikad plaanid
- C) Sest hädaolukorras ei ole aega pikki dokumente lugeda
- D) Et plaani ei peaks harjutama

Õige vastus: C